2038: The Next Epochalypse

2038

Breaking time before it breaks us

Lorenzo DINA

whoami

Lorenzo DINA

- ex CIO, ex CEO, Founder

- Innovation & R&D Manager @ BIT4LAW
- Cybersecurity and ICS/OT troublemaker @Nobug

- I maintained a Gopher before the WWW won



Standing on the shoulders …

This presentation also draws on the work, research, and materials previously developed by:

Trey Darley

Pedro Umbelino

XSTP.epoch authors (+me)



AI Disclaimer

Some components of this talk were developed with the support of generative artificial intelligence tools. This use is intentionally documented. The choice to state this explicitly — rather than omitting it — is itself a methodological act.
Responsibility for reviewing the material remains with the author.



Saint Augustine’s three presents in the cyber realm

Memory and expectation shape the present we experience

MEMORY

The past held in the present

→ Logs, Y2K experience

EXPERIENCE

What we perceive now

→ Authorization decisions

EXPECTATION

The future imagined now

→ Expiration, scheduled jobs, smart contract

Our systems also act on what they remember, observe and expect.

Sources: Augustine, Confessions XI.20

The elastic “mo”

A Roman expression for a very flexible notion of “now”

“Mo lo faccio.”

MO

“I’ll do it in a moment.”

HUMAN “MO”

Context can absorb a delay that may never end.

SYSTEM “NOW”

A validity check needs an explicit window.

Roman “mo” has no published SLA.

Sources: https://en.wiktionary.org/wiki/mo#Italian

Now is a distributed agreement

Systems coordinate because three assumptions usually hold

NOW

No machine owns it.
Every system acts on it.

Time becomes infrastructure when disagreement changes authorization, causality or safety.

01 **Representation**

The same bits mean the same instant.

02 **Synchronization**

Clocks remain within an accepted bound.

03 **Interpretation**

Past, present and future stay ordered.

A bug and a vulnerability class are different problems

Risk crosses ownership, formats and replacement cycles

BUG

One component

- Known owner
- Bounded call path
- Patch closes the defect

VULNERABILITY CLASS

Many boundaries

- Formats and interfaces diverge
- Owners and lifecycles are distributed
- A fixed date correlates failures

Coordination becomes a security control.

Common Weakness Enumeration

covers some weakness mechanism leading to the vulnerability class

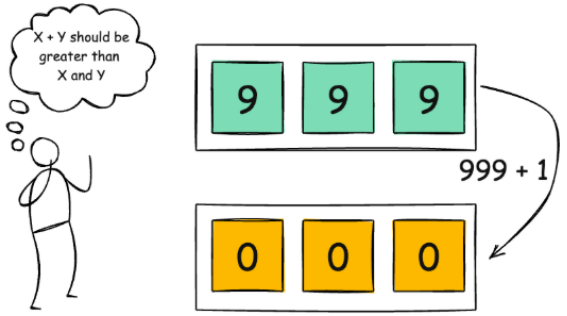
CWE-190: Integer Overflow or Wraparound

Weakness ID: 190
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | **Complete** | Custom

Description

The product performs a calculation that can produce an integer overflow or wraparound when the logic assumes that the resulting value will always be larger than the original value. This occurs when an integer value is incremented to a value that is too large to store in the associated representation. When this occurs, the value may become a very small or negative number.



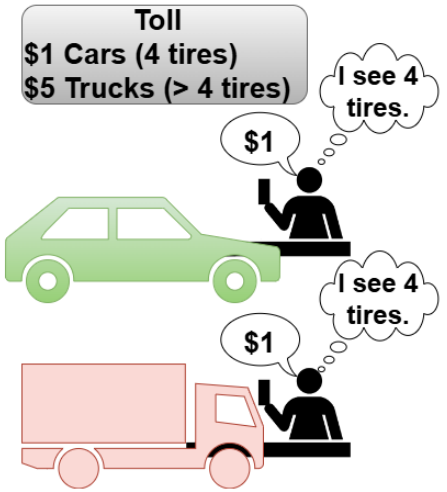
CWE-697: Incorrect Comparison

Weakness ID: 697
Vulnerability Mapping: DISCOURAGED
Abstraction: Pillar

View customized information: Conceptual | Operational | Mapping Friendly | **Complete** | Custom

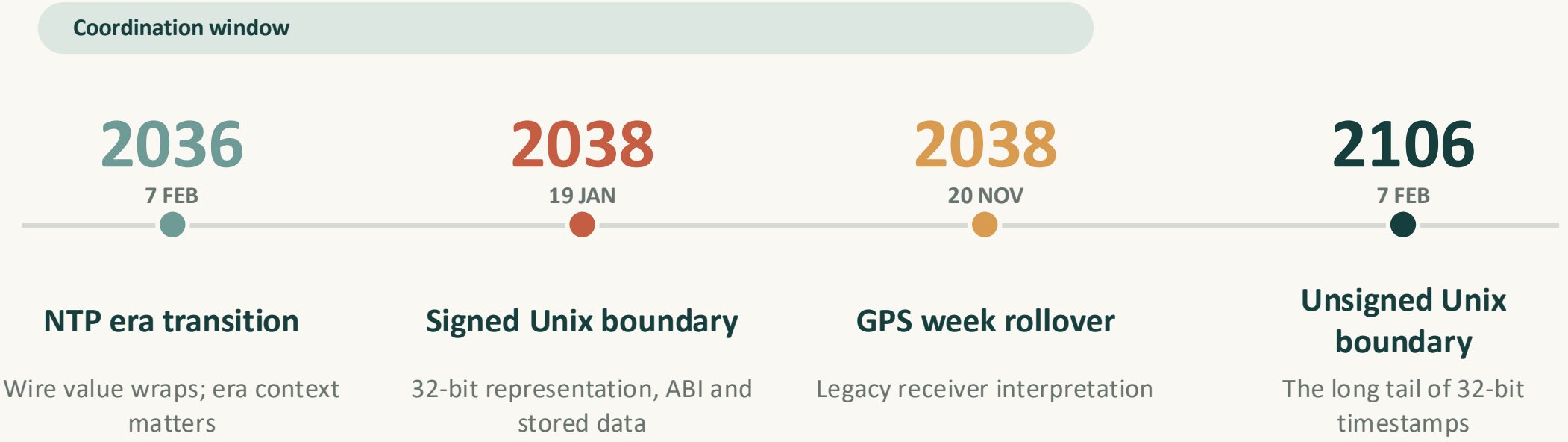
Description

The product compares two entities in a security-relevant context, but the comparison is incorrect.



Rollover cluster and long tail

Distinct mechanisms arrive inside one coordination window



Timeline spacing is schematic

Sources: RFC 5905 · GPS.gov · ITU-T XSTP.epoch Version 1

2036 changes the meaning of the wire value

NTP seconds wrap; receivers need context to identify Era 1

7 FEB 2036 · UTC

06:28:15

FFFFFFFF

last second field in Era 0

06:28:16

00000000

first wire value in Era 1

Interpretation

Robust

Infer Era 1 from a plausible nearby date.

Fragile

Interpret zero as 1900 or as an invalid clock.

RFC 5905 (NTPv4) requires nearby context: adjacent eras are unambiguous only inside a 68-year window.

Source: RFC 5905 · NTP timestamp format and era model

2038 flips the sign of 32-bit Unix time

The failure applies to signed 32-bit implementations and their dependencies

03:14:07 UTC

2,147,483,647

01111111 11111111 11111111 11111111

03:14:08 UTC

–2,147,483,648

10000000 00000000 00000000 00000000

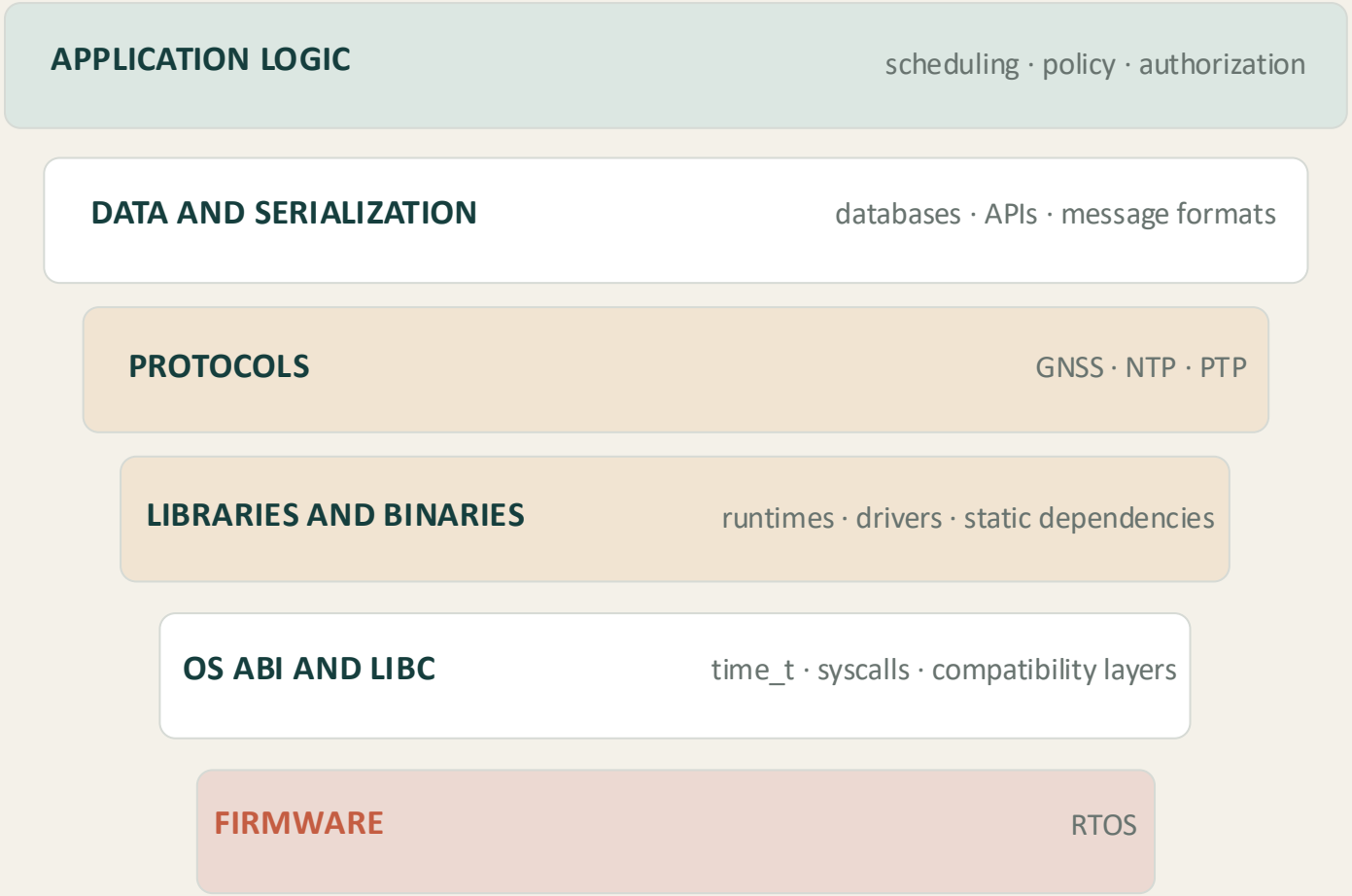
19-Jan-2038 becomes **13-Dec-1901** when software interprets the result as signed 32-bit time

A jump to 1970 may indicate a zero/default fallback, not the signed overflow itself.

References: POSIX time interfaces · ITU-T XSTP.epoch Version 1

The hard boundary sits between components

Architecture reviews must follow timestamps across layers



Boundary heuristic

A 64-bit kernel may still play host to a vulnerable application/library, and 64-bit hardware can still have 32-bit vulnerabilities in it.

Trace the timestamp, not the product label.

The risk lives in the interface contract and the lifecycle mismatch.

BigTime maps platform-scale time concentration

One 2025 study measured seven large providers from public vantage points

6.6B+

estimated active devices default to vendor time services

Amazon
Apple
Cloudflare
Google
Meta
Microsoft
Ubuntu

MICROSOFT

One NTP server appeared for roughly half of measured vantage points.

TIME QUALITY

Three Microsoft servers deviated by as much as 50 ms during measurement.

DEFENSE STACK

Only Cloudflare combined NTS, RPKI and DNSSEC

Source: Huppert et al., BigTime, SIDN Labs technical report, 1 Dec 2025

Time is a security dependency

Security controls fail in different ways when clocks diverge

NOW

A shared assumption with no single owner

Coherence matters more than perfect agreement.

- Certificate and revocation validation
- Kerberos and TOTP clock-skew checks
- DNSSEC and RPKI validity windows
- Log ordering and forensic reconstruction
- Billing, settlement and regulatory evidence

Routine operations exposed the hidden dependency

The trigger was often ordinary; the time path was not

2017	**Future-date test**	RATP rolling stock
2019	**Scheduled rollover**	GPS receivers in aircraft
2025	**Manual time change**	ProGauge automatic tank gauges
2026	**Planned chassis replacement**	Telstra mobile network

The calendar boundary became visible during testing, maintenance or controlled input.

RATP and Alstom: dates became a contract dispute

A 2017 test surfaced a software horizon in long-lived rolling stock

38
embedded programs affected

>⅓
of the RATP network may be impacted

1.4M/day
passengers potentially impacted

01 2017 test

A future-date exercise exposed failures beyond 2037.

02 13 Nov 2025

The Paris Administrative Court ordered an assessment. The decision remains under appeal.

03 Remediation horizon

The order allowed 12 months for assessment and up to five years for remediation.

Operational life exceeded the representable horizon, then ownership had to be litigated.

GPS rollover: guidance existed, aircraft still grounded

The 2019 event exposed the gap between advisories and deployed fleets

12+

Boeing 787 aircraft reported grounded

≥1

Boeing 777 also reported

1999

date shown after receiver rollover

10-bit week number

1023 weeks

≈19.7 years between rollovers

Operational gap

Guidance had been issued in March 2019. Affected operators had not applied it before the April rollover.

NEXT LEGACY C/A

20 NOV 2038

Sources: GPS.gov · ITU-T XSTP.epoch Version 1 · EASA guidance cited in the case study

ProGauge: time manipulation becomes DoS

A deterministic boundary creates a present input-validation problem

CVE-2025-55068

INPUT 01

An attacker changes system time beyond the supported Unix range.

STATE 02

The device fails to handle the out-of-range value safely.

IMPACT 03

Authentication errors and denial of service follow.

Automatic tank gauges sit inside fuel and backup-power chains. Availability failure can propagate beyond the device.

Sources: CVE.org and NVD · CVE-2025-55068

Telstra: one stale GPS card rewrote network time

A planned maintenance event activated a 19.7-year rollback

01 Planned replacement

Engineers replaced an NTP timing chassis in Melbourne.

02 GPS card reset

Unpatched firmware restarted its date in November 2006.

03 Time propagated

Undocumented stratum and peering behavior promoted the wrong source.

04 Control plane failed

Date-sensitive certificates and session systems disrupted service.

≈45%

of calls and data sessions were affected, according to Telstra's press release.

Control lesson

Patch status, topology and documentation belong in the same timing-system review.

Source: Technology Audit Partners · Findings Report on 8 July 2026 Telstra outage fort causal chain; Telstra for the peak impact.

Four cases reveal four routes to the same class

Different triggers converge on representation, authority and lifecycle gaps

Case	Trigger	Hidden boundary	Operational impact	Control lesson
RATP	Future-date test	Rolling-stock software horizon	Fleet availability risk	Test the full asset horizon
GPS / Boeing	Scheduled rollover	10-bit week interpretation	Aircraft grounded	Close advisory deployment gaps
ProGauge	Manual time change	Unsupported Unix range	Auth errors and DoS	Treat future time as input
Telstra	Planned maintenance	GPS rollback plus time topology	Mobile calls and data disrupted	Review patching and authority

A fixed date creates shared urgency, but controls must follow each failure path.

We are going on a bear hunt...

We are going on a bear hunt...

Visible product limits reveal hidden representation horizons

1970

SUPPORTED EVENTS



2037

SUPPORTED EVENTS

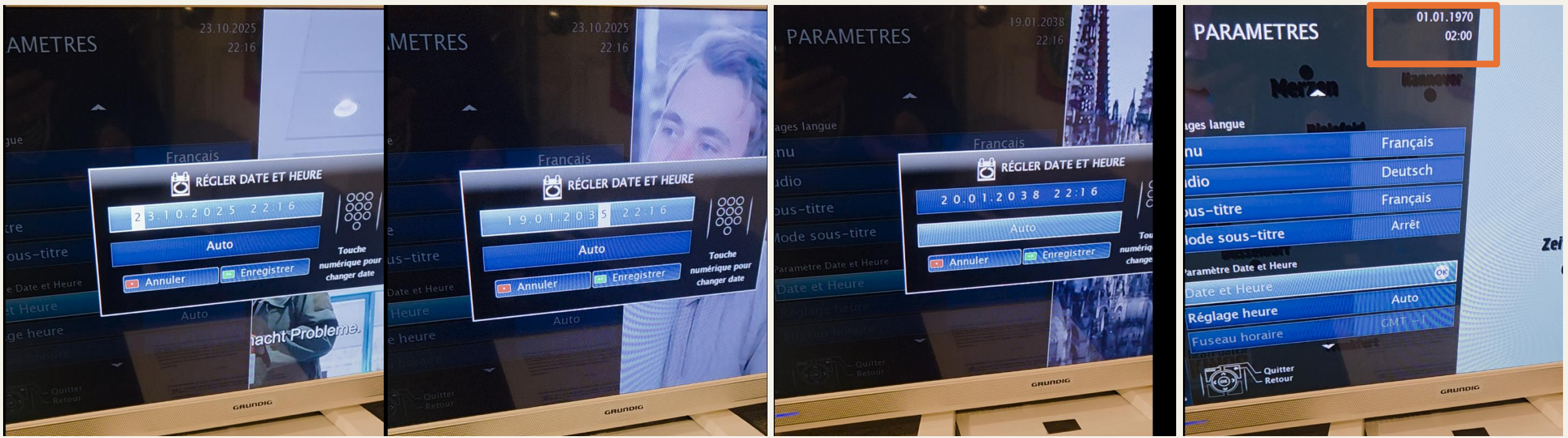
Proton Calendar supports events between these endpoints.

The boundary is documented. The dependency chain behind it is usually invisible.

Source: Proton Support · calendar import date range

We are going on a bear hunt...

Hotel Smart TV

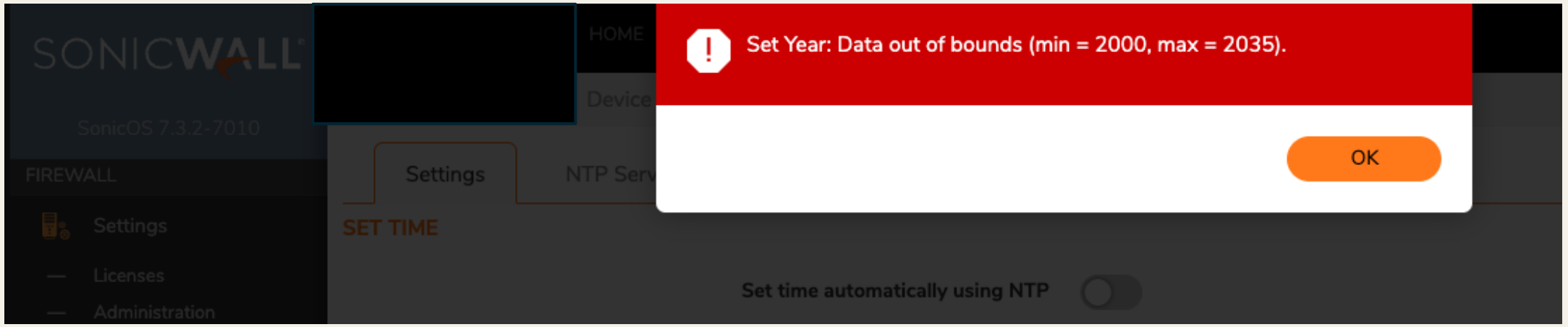


Observed reset, root cause unconfirmed

Sources: Personal test on a random hotel Smart TV

We are going on a bear hunt...

Firewall



Explicit 2035 input limit; implementation cause unconfirmed

Sources: Personal test on a Sonicwall firewall TZ670 SonicOS 7.3.2-7010

We are going on a bear hunt...

find on a macOS

```
joecondo@MacBook-Max-di-Joecondo ~ % find / -newermt "2038-02-19"
find: /usr/sbin/authserver: Permission denied
find: /Library/Application Support/Apple/ParentalControls/Users: Permission denied
find: /Library/Application Support/Apple/AssetCache/Data: Permission denied
find: /Library/Application Support/ApplePushService: Permission denied
find: /Library/Application Support/logitune/sentry: Permission denied
find: /Library/Application Support/Microsoft/Defender/enginedb: Permission denied
find: /Library/Application Support/com.apple.TCC: Operation not permitted
^C
joecondo@MacBook-Max-di-Joecondo ~ % find / -newermt "2038-02-20"
find: /usr/sbin/authserver: Permission denied
find: /Library/Application Support/Apple/ParentalControls/Users: Permission denied
find: /Library/Application Support/Apple/AssetCache/Data: Permission denied
find: /Library/Application Support/ApplePushService: Permission denied
find: /Library/Application Support/logitune/sentry: Permission denied
find: /Library/Application Support/Microsoft/Defender/enginedb: Permission denied
find: /Library/Application Support/com.apple.TCC: Operation not permitted
^C
```

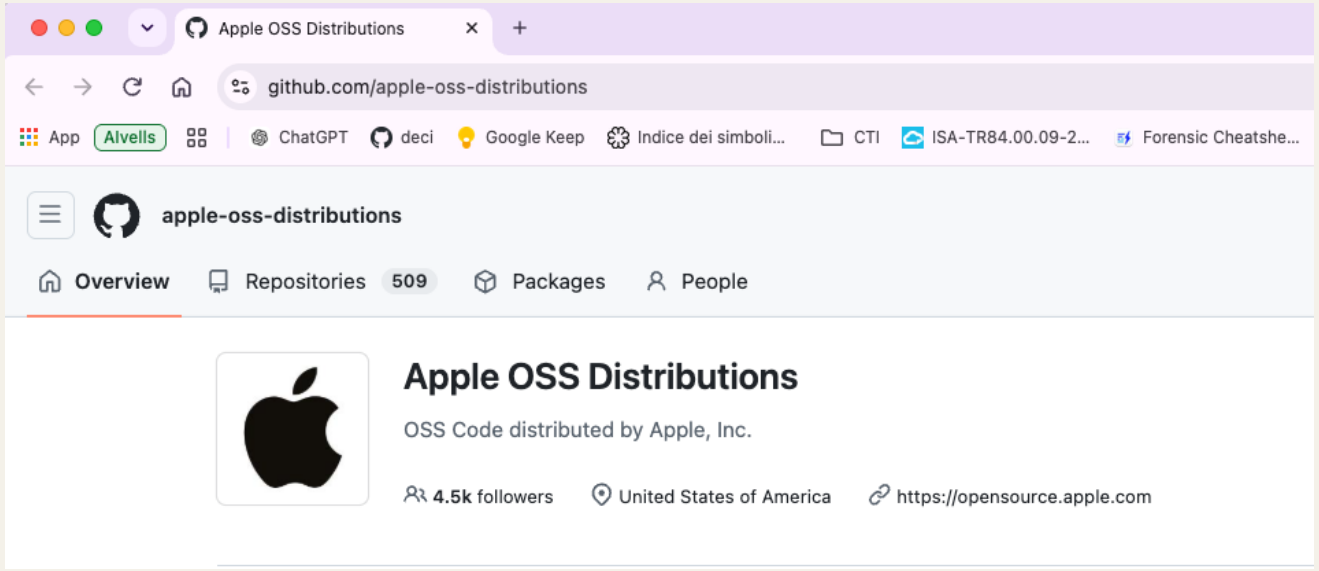
```
joecondo@MacBook-Max-di-Joecondo ~ % find / -newermt "2039-01-01"
find: Can't parse date/time: 2039-01-01
find: /usr/sbin/authserver: Permission denied
find: /Library/Application Support/Apple/ParentalControls/Users: Permission denied
find: /Library/Application Support/Apple/AssetCache/Data: Permission denied
find: /Library/Application Support/ApplePushService: Permission denied
find: /Library/Application Support/logitune/sentry: Permission denied
find: /Library/Application Support/Microsoft/Defender/enginedb: Permission denied
find: /Library/Application Support/com.apple.TCC: Operation not permitted
^C
joecondo@MacBook-Max-di-Joecondo ~ % for d in 2038-12-31 2039-01-01 2040-01-01; do
    /usr/bin/find /tmp -newermt "$d" >/dev/null 2>&1
    echo "$d → exit $?"
done
2038-12-31 → exit 0
2039-01-01 → exit 1
2040-01-01 → exit 1
```

Verified source-level

Sources: find utility on MacOS 14.8.4 (23J319) and 26.6.2 https://github.com/apple-oss-distributions/shell_cmds/blob/298787009e5432c5e4c378a077f98267077e3495/find/getdate.y#L586-L592

We are going on a bear hunt...

find on a macOS



/apple-oss-distributions/shell_cmds/blob/298787009e5432c5e4c378a077f98267077e3495/find/getdate.y#L586-L592

deci | Google Keep | Indice dei simboli... | CTI | ISA-TR84.00.09-2... | Forensic Cheatshe... | Feed | LinkedIn

shell_cmds / find / getdate.y

Code | Blame | 948 lines (851 loc) · 23 KB

```
573         time_t  tod;
574         time_t  Julian;
575         int     i;
576
577         if (Year < 0)
578         Year = -Year;
579         if (Year < 69)
580         Year += 2000;
581         else if (Year < 100)
582         Year += 1900;
583         DaysInMonth[1] = Year % 4 == 0 && (Year % 100 != 0 || Year % 400 == 0)
584                 ? 29 : 28;
585         /* Checking for 2038 bogusly assumes that time_t is 32 bits.  But
586            I'm too lazy to try to check for time_t overflow in another way.  */
587         if (Year < EPOCH || Year > 2038
588          || Month < 1 || Month > 12
589          /* Lint fluff:  "conversion from long may lose accuracy" */
590          || Day < 1 || Day > DaysInMonth[(int)--Month])
591         return -1;
592
593         for (Julian = Day - 1, i = 0; i < Month; i++)
594         Julian += DaysInMonth[i];
595         for (i = EPOCH; i < Year; i++)
596         Julian += 365 + (i % 4 == 0);
597         Julian *= SECSPERDAY;
598         Julian += yyTimezone * 60L;
599         if ((tod = ToSeconds(Hours, Minutes, Seconds, Meridian)) < 0)
600         return -1;
601         Julian += tod;
602         if (DSTmode == DSTon
603          || (DSTmode == DSTmaybe && localtime(&Julian)->tm_isdst))
604         Julian -= 60 * 60;
605         return Julian;
606     }
```

Sources: find utility on MacOS 14.8.4 (23J319) and 26.6.2

We are going to catch a big one...

The bear is a date Windows wrote down twenty years ago in Kerberos.

THE BEAR

20370913024805Z

Windows Kerberos' "never expires" · 13 Sep 2037, 02:48:05 UTC

WHERE

Active Directory Kerberos — the identity fabric of nearly every enterprise — and the seam between Windows and everything else that authenticates to it.

HOW

The protocol is fine. "Never" just needs a finite date: Windows picked 2037 to fit 32-bit Unix time. Server 2025 moved it to 2100 — which overflows every signed 32-bit time_t downstream.

NOW

Windows Server 2025 DC → "never" = 2100 → **32-bit krb5 · GSSAPI**
Cisco ISE · appliances

✗ can't decode the ticket → authentication fails

SEP 2037 (scenario)

Pre-22H2 clients
XP · 7 · 10 · OT HMIs → "never" = 2037 → **Any domain controller**

✗ "never" is in the past → logon & Group Policy fail



Source: T. Darley, "On the Mineshaft Gap", VulnOptiCON, Luxembourg, 25 Sep 2026 · TLP:CLEAR

The hunt is local.
The failure class is systemic.

XSTP.epoch creates a coordination layer

Revision 1 gives fragmented rollover work a common frame

REVISION 1 | JUNE 2026 | INFORMATIVE

01

Shared frame

Seven failure-mode classes and nine analytical dimensions support comparable assessments.

02

Cross-sector map

Section 10 surveys thirty sectors +1 using a common taxonomy and evidence model.

03

Revision process

A living document absorbs incidents, tests and sector expertise on a roughly six-month cadence.

Agreed by ITU-T SG17 and developed with the FIRST Time Security SIG community.

Source: ITU-T XSTP.epoch Version 1

The sector map is intentionally unfinished

XSTP.epoch needs evidence that only practitioners can supply

DEVELOPED TREATMENTS INCLUDE

- Telecommunications
- Financial systems
- Electric and connected vehicles
- Implantable and hospital devices

CONTRIBUTION TARGETS

- Citable incidents and near misses
- Device and asset lifecycles
- Protocol and data boundaries
- Test methods and regulatory constraints

Epistemic risk also matters: documentation decays, expertise leaves, and automated tools reproduce legacy assumptions.

Source: ITU-T XSTP.epoch Version 1 · Sections 10 and 11

Section 10 surveys thirty sectors

The map spans digital coordination, physical operations and long-lived assets

INFORMATION AND COORDINATION

- 01 Telecommunications networks
- 02 Financial systems
- 06 CSIRT / PSIRT / CERT
- 09 Cloud and ICT infrastructure
- 10 GNSS-dependent services
- 11 Space infrastructure
- 12 Broadcasting and alerts
- 13 Government services
- 14 Insurance / reinsurance
- 15 Epistemic coordination

LIFE, INDUSTRY AND RESOURCES

- 03 Biological research / pharma
- 05 Implantable / hospital devices
- 08 ICS / OT environments
- 16 Buildings
- 17 Manufacturing
- 19 Mining and extraction
- 20 Water and wastewater
- 21 Food and farming
- 22 Oil and gas
- 30 Waste and recycling

ENERGY AND MOVEMENT

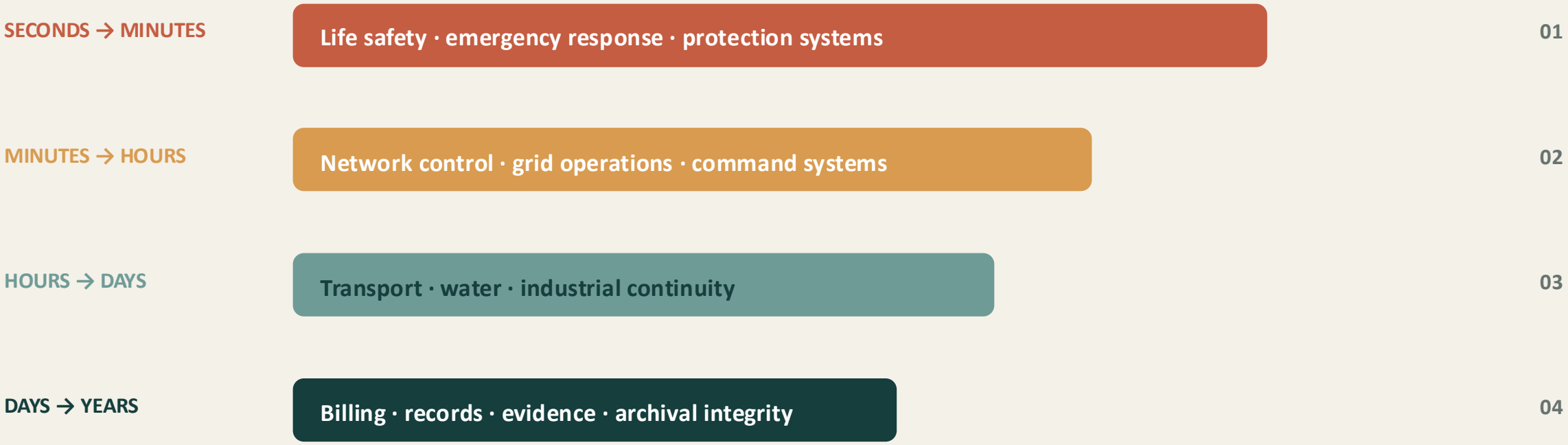
- 04 Electric / connected vehicles
- 07 Emergency services
- 18 Logistics and distribution
- 23 Power plants
- 24 Power grid
- 25 Vehicles / traffic
- 26 Railroad
- 27 Bridges and tunnels
- 28 Aviation
- 29 Shipping

Coverage is broad. Evidence depth remains uneven, which is why the section is also a contribution map.

Source: ITU-T XSTP.epoch Version 1 · Section 10

Triage by failure tempo

Prioritize how quickly a wrong timestamp becomes irreversible harm



Remediation has an ethical footprint

Premature replacement creates e-waste. Exporting legacy equipment exports future risk to regions with fewer remediation options.

The ITD cycle turns awareness into evidence

Inventory, test in situ, then demand proof from suppliers

01

INVENTORY

Find representations, protocols, time sources, dependencies and asset lifetimes.

02

TEST IN SITU

Advance dates in realistic environments and observe control, data and recovery paths.

03

DEMAND EVIDENCE

Require supported horizons, test results, remediation plans and ownership commitments.

TBoM **A Time Bill of Materials is an emerging proposal for future revisions, not an established standard.**

Source: ITU-T XSTP.epoch Version 1 · readiness actions and future work

Resilient time needs independent failure paths

A trustworthy design combines diversity, authentication and operational rejection

SOURCES	GNSS · national laboratories · network peers
DISTRIBUTION	NTP / NTS · PTP · independent paths
VALIDATION	authentication · sanity bounds · multi-source comparison
HOLDOVER	local oscillator · reject impossible jumps
OPERATIONS	drift monitoring · alerting · incident procedures

COHERENT TIME

No single reference, protocol or operator should define reality alone.

Detect divergence. Preserve holdover. Reject implausible steps.

References: RFC 8915

Help write the next XSTP.epoch revisions

Contribute evidence before the boundary becomes an incident.

SECTOR SPECIALISTS

Map operational dependencies and long asset lifecycles.

RESEARCHERS + MAINTAINERS

Bring protocols, code paths, test methods and citable results.

OPERATORS + IR / FORENSICS

Document incidents, near misses and recovery constraints.

Join the FIRST Time Security SIG

first.org/global/sigs/time



Q&A

lorenzo.dina@nobug.it

Resources

- FIRST.org Time Security – SIG
  - https://www.first.org/global/sigs/time/
- The Epochalypse Project
  - https://epochalypse-project.org/en/
- XSTP.epoch
  - https://www.itu.int/ITU-T/workprog/wp_item.aspx?isn=23741
- IEEE P4150
  - standards.ieee.org/ieee/4150/12603/
- Darley T. “On the Mineshaft Gap”, VulnOptiCON
  - propertools.be/talks/vulnopticon-2026-mineshaft-gap/vulnopticon-2026-mineshaft-gap.pptx